WEEK 4 – TASK D

Distinction Task.
Release Date: 28/7-4/8/2025

Learning Outcomes

- Create obfuscated malicious executable
- Demonstrate exploitation using Metasploit
- Demonstrate escalation privileges using bypass_uac exploitations
- Demonstrate maintaining persistence in Windows 10 using new user accounts and remote protocol.
-

Instructions

Instructions

 **To complete this task, you must attempt all** questions/tasks with the icon below. If screenshots are required, please ensure that the text in the screenshots is readable.

Remember that troubleshooting technical problems is part of learning in this field. Tasks are not a step-by-step guide. You need to be in the driver's seat and learn concepts by doing – as you would when you start your future job (many times, even your teacher does not know the answer to problems you face). **Do your research patiently to solve issues you face.**

Hacking Windows 10 machine

The **Metasploit Framework** is one of the most widely used and powerful tools in the cybersecurity field. It is commonly used by ethical hackers and penetration testers to discover, exploit, and validate vulnerabilities in systems. One of its key features is the ability to create **listeners** and launch exploits that, when successful, provide access to a compromised machine via a powerful post-exploitation shell known as the **Meterpreter.**

In this task, you will work within a virtual lab environment consisting of **pfSense**, **Kali Linux**, and **Windows 10**. You will simulate a complete system hacking scenario by progressing through several key phases that reflect real-world attacker behavior. These stages include:

- **Creating a malicious executable** designed to establish a reverse connection back to the attacker (Kali).

- **Obfuscating the payload** to bypass Windows Defender and other antivirus mechanisms on the target machine.
- **Delivering and executing the exploit** on the Windows 10 system to gain initial access.
- **Escalating privileges** to gain higher-level control over the compromised system.
- **Establishing persistence** to maintain long-term access even after a reboot.



Task1: Use Metasploit in Kali Linux and then use "msfvenom -p windows/ meterpreter/ reverse_tcp" to create the malicious executable. You need to do your search to find how to create this malicious executable for Windows x86 using this command. You need to add few things to create this malicious. Provide screenshot of your command and output.

Windows systems are equipped with built-in security mechanisms such as **antivirus software**, **real-time threat protection**, and **Windows Defender**, all designed to detect and block known malicious payloads. As a result, simply generating a payload using tools like `msfvenom` is no longer sufficient for successful exploitation. While `msfvenom` makes it easy to create custom payloads, its popularity has led to the development of antivirus signatures that specifically detect and block these payloads. To bypass these defenses, it is essential to **obfuscate or encode your payload** in a way that alters its signature without affecting its functionality. This process helps evade detection by antivirus engines. In this task, you will explore encoding techniques to make your payload less recognizable to security tools, thereby increasing your chances of successfully delivering and executing it on a Windows system.



Task 2: For this task, you need to combine any two encoding techniques. You can check all existing encoding techniques using "msfvenom -l encoders". However, you should combine any two techniques a) without affecting the functionality of the malicious executable and b) Apply 10 iterations for the first encoder and 2 iterations for the second encoder. Explain how you combined. Which techniques? Provide screenshots of your command and output.

Once you've successfully generated and double-encoded your malicious executable, the next step is to **transfer it to the Windows 10 machine** in your lab environment. In real-world scenarios, attackers commonly deliver such payloads through **social engineering techniques**, such as **phishing emails**, malicious attachments, compromised websites, or USB devices. These methods are designed to trick users into executing the payload without raising suspicion. To do this, start a simple HTTP server on your **Kali Linux machine** using Python, then use **PowerShell on the Windows 10 machine** to download the payload directly. This approach mirrors how attackers often host malicious files on remote servers and trick users or systems into downloading them.

Task 3: Provide screenshots and explain the steps you followed in Kali and Windows 10 to transfer the payload to Windows 10.

important: If your malicious executable is still being detected and removed by Windows 10 despite applying combined encoding, you may need to temporarily disable **Windows Defender's real-time protection**. To do this, go to **"Virus & Threat Protection" settings**, turn off **real-time protection**, and then try transferring and executing the file again within the lab environment.

When you execute the malicious payload on the Windows 10 machine, it will attempt to establish a reverse connection back to your Kali Linux system using **Meterpreter** via the Metasploit framework. Before running the payload, you must first set up a listener in Metasploit. Ensure that the listener's configuration — including the payload type (windows/meterpreter/reverse_tcp), LHOST, and LPORT — matches exactly the settings used when generating the payload. This alignment is essential for a successful connection.

Task 4: Provide screenshots and explain the steps you followed in Kali to create this session with the malicious code.

Task 5: After you set the payload and then run, you should be able to open a session with Windows 10. Check the current privilege that you have. Then, use hashdump for dumping the plaintext passwords of logged-in users from memory. What was the result? What does this mean? Provide screenshots of your commands.

Privilege escalation enables you to elevate your access from a limited user account to a higher-privileged one, such as the administrator. Start by trying the built-in Meterpreter command `getsystem` to attempt automatic privilege escalation. However, **regardless of whether `getsystem` succeeds or not, you should proceed to test available authentication bypass and privilege escalation exploits within Metasploit**. Use the command `search uac` to find relevant exploits. Remember to background your current Meterpreter session before launching a new exploit. Focus on testing exploits designed for Windows x86 systems and your machine build version and then determine which one successfully opens a new, elevated session on the Windows 10 target machine.



Task 6: In this task, run the getsystem command and explain what it does, including why it succeeded or failed. Then, try a UAC bypass exploit, state which one you used. After escalating privileges, run hashdump again and compare the results to before. Explain any differences and support your answer with screenshots of the commands and outputs.

To maintain persistence on a Windows 10 system, you can create a new user account (e.g., using your name) and assign it a secure password, allowing you to reconnect to the machine at any time. To ensure full access, add the user to the administrators group and enable Remote Desktop Protocol (RDP) access for the account. RDP is Microsoft's proprietary protocol that enables remote connections to Windows systems and is commonly used by attackers as a persistence technique to maintain access to compromised machines. Use a remote access tool such as Remmina from your Kali machine to verify the connection. Document each step, justify your choices, and include screenshots of your configuration and successful login.

Hint: **To enable RDP on the target machine, you may need to modify the Windows registry by adding or updating specific keys to allow remote connections. Consider researching how to enable RDP via the registry as part of your solution.**



Task 7: Provide screenshots of your commands and outputs. Also, provide a screenshot of your connection to Windows 10 from your Kali Linux on RDP.